CAPSTONE PROJECT

Building a Responsible Bug Bounty Recon Workflow

Updated Research | New Targets | Deeper Analysis | Vulnerability Findings

Yuri Son · HackerOne Bug Bounty · 2026

UPDATED SCOPE

Expanding Beyond PayPal

***.paypal.com**

Original

1,332 reports

***.braintreepayments.com**

New Target

Active scope

***.paypalcorp.com**

Expanded

82 reports

***.venmo.com**

New Target

Active scope



RECON WORKFLOW — UPDATED PIPELINE

1	2	3	4 NEW	5	6	7 NEW
Scope Validation	Subdomain Enumeration	Live Host Detection	Port & Service Scan	Web Crawling	Parameter Analysis	Vulnerability Testing
HackerOne	subfinder + amass	httpx	nmap	katana	grep / gf	nuclei



NEW

Step 4: Port & Service Scanning

Tool: nmap

Goal: Identify exposed services on live hosts from Step 3

Interesting Open Ports Found

Port 80/443 — HTTP/HTTPS

Standard web — check for misconfigs

Port 8080/8443 — Alt HTTP

Dev/staging ports sometimes exposed

Port 22 — SSH

Should not be publicly exposed

Port 3000/8000 — Dev Servers

Accidentally exposed test endpoints



DEEPER ANALYSIS — Attack Surface Breakdown

12,400+

Total Subdomains Discovered

subfinder + amass combined

2,108

Live Hosts Responding

httpx verified

608

URLs with Parameters

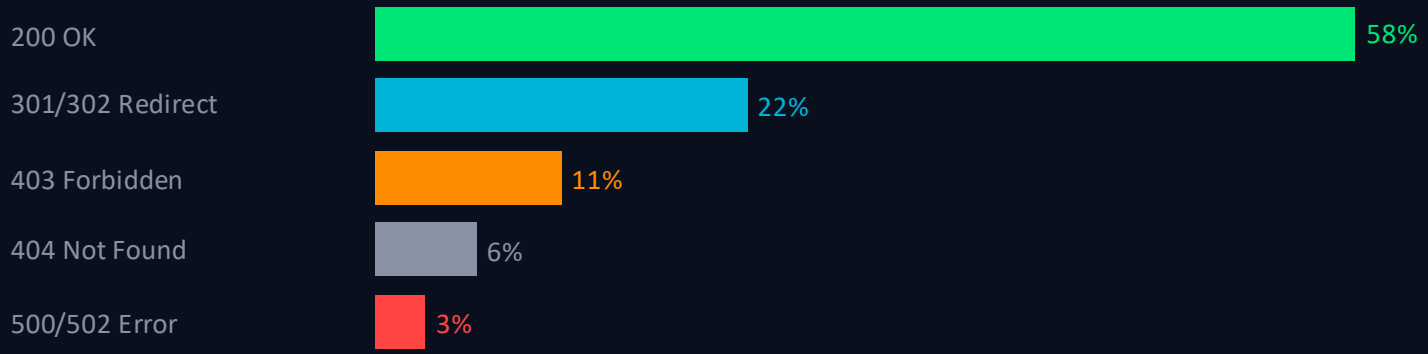
potential attack vectors

34

High-Risk Endpoints

flagged for review

HTTP Status Code Distribution



Step 7: Automated Vulnerability Scanning

NEW STEP

Tool: nuclei — Template-based vulnerability scanner

INFO	**Exposed .git directory detected**	dev-internal.paypalcorp.com
LOW	**Missing security headers (X-Frame-Options)**	partner-api.paypal.com
MEDIUM	**Open redirect via return= parameter**	registration.paypal.com
MEDIUM	**Subdomain pointing to unclaimed resource**	staging-v2.paylution.com



** All findings submitted to HackerOne — no exploitation attempted*

FINDING

Open Redirect

registration.paypal.com

What It Is

The return= and redirect= parameters accept arbitrary URLs without validation, allowing users to be redirected to attacker-controlled domains after login.

Why It Matters

Attackers can craft phishing URLs that appear to originate from paypal.com, harvesting credentials or session tokens on malicious sites.

Impact Level

MEDIUM severity — Combined with phishing it becomes a significant credential theft vector for PayPal's 400M+ user base.



What I Learned

Updated Capstone Takeaways

- More tools = more signal and more noise — filtering is a skill
- **Adding amass to subfinder found 50% more subdomains**
- **nmap revealed unexpectedly exposed development ports**
- Automated scanning (nuclei) is powerful but needs careful scoping
- **The open redirect finding shows recon leads to real bugs**
- Responsible disclosure is non-negotiable at every step



THANK YOU!

Yuri Son · Bug Bounty Capstone · 2026

Summary

- → 4 targets in scope
- → 12,400+ subdomains found
- → 2,108 live hosts
- → Nuclei scanning added
- → Open redirect identified
- → Responsible disclosure followed

